💼 Executive Summary

💼 Executive Summary

Xibalba Interactive confronts persistent cyber threats from diverse threat actors (TAs), who aim to exploit weaknesses across our attack surface to steal data and disrupt operations. Key attack surfaces include vulnerable development servers, exposed file repositories, and application code vulnerabilities. These threats put user data, intellectual property, and our reputation at risk.

To proactively harden these attack surfaces and defend against threat actors, we are implementing key security improvements. First, we are strengthening account security with robust passwords and better access controls, limiting the impact of compromised credentials. Second, we will deploy early warning systems to detect intruders quickly, including web bugs on exposed systems and strategic honey pot placement of credentials and tokens. These tools will alert us to attacker activity. Data from these mechanisms will flow to the SIEM to correlate events. Third, we will implement command data monitoring to identify unauthorized processes initiated by threat actors.

These improvements are designed to actively protect data, reduce risk, and ensure compliance with legal and regulatory mandates. Addressing vulnerabilities and strengthening defenses will safeguard our business from evolving cyber threats and bolster our resilience. An awareness program will empower our team to report threats.

Threat Model

Threat Model for Xibalba Interactive

🥷 Threat Actors

🥷 Threat Actors

1. THREAT ACTOR: Cybercriminals
Cybercriminals could want to attack for reasons of theft, fraud, monetizing stolen payment details or credentials. They could achieve this through phishing emails, malware infections, installing ransomware, credit card skimming , or fake logins.

- **SCENARIO: Exploited public facing applications**
- T1190: Exploit Public-Facing Application
- T1078: Valid Accounts
- T1005: Data from Local System
- An attacker exploits a vulnerability on a public-facing web server.The attacker uses stolen credentials to access the vendor's development environment.They locate and exfiltrate sensitive data.

2. THREAT ACTOR: Advanced Persistent Threats (APTs)
APT's could want to attack for reasons of undetected foothold, credential harvesting, long term access to personal material, or sabotage. They could achieve this through sophisticated data exfiltration or lateral movement within networks, access to Internal development server, spear phishing, zero day exploits, fileless malware, custom malware, supply chain attacks, or zero day exploits.

- **SCENARIO: Network sniffing for IP**
- T1040: Network Sniffing
- T1078: Valid Accounts
- T1005: Data from Local System
- The attacker gains access to a network segment and begins passively capturing network traffic. The attacker identifies a user's credentials from the sniff network traffic. Using the compromised credentials, and accessing sensitive IP data.

3. THREAT ACTOR: Insider Threats
Insider threats including any employees and users with valid credentials could want to exploit the company for revenge, financial incentives from competitors, leverage, personal gain, or retribution. They could achieve this through misuse of credentials, downloading on personal devices, sharing login credentials, deleting or sabotaging.

- **SCENARIO: Insider threat**
- T1078: Valid Accounts
- T1005: Data from Local System
- A company employee uses credentials to download company IP and sell it to competitors.

⚔️ Attack Surface

⚔️ Attack Surface

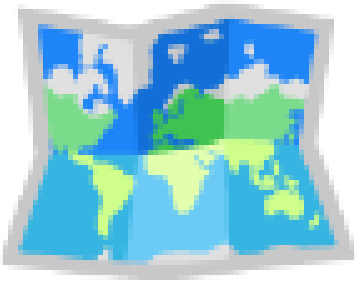
⚔️ **Attack Surface** **1**
encryption 1
gamers 1
messages 1
chat system 1
.git folder 1
development server 1
API server 2
git hub 2
VPN system 2
developers 2
laptops 2
credentials database 2
payment processing server 2
employees 2
PCI 2
PCI software 2
network traffic 2

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
encryption	In-game private chat system	• T1555.03: Credentials from Web Browsers	1 (Rare)	4 (Major)
gamers	In-game private chat system Payment information (PCI)	• T1003: Credential Dumping	4 (Like…	3 (Mod…
messages	In-game private chat system	• T1557: Adversary-in-the-Middle	3 (Pos…	3 (Mod…
chat system	In-game private chat system	• T1190: Exploit Public-Facing Application	2 (Unli…	3 (Mod…
.git folder	Intellectual property (IP)	• T1505: Server Software Component	5 (Alm…	4 (Major)
development server	Intellectual property (IP)	• T1005: Data from Local System	4 (Like…	4 (Major)

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
API server	Intellectual property (IP)	• T1078: Valid Accounts	4 (Like…	5 (Cata…
git hub	Intellectual property (IP)	• T1649: Steal or Forge Authentication Certificates	4 (Like…	4 (Major)
VPN system	Intellectual property (IP)	• T1199: Trusted Relationship	3 (Pos…	4 (Major)
developers	Intellectual property (IP)	• T1609: Container Administration Command	2 (Unli…	4 (Major)
laptops	Intellectual property (IP)	• T1555: Credentials from Password Stores	3 (Pos…	4 (Major)
credentials database	Intellectual property (IP) personally identifiable information (PII), Payment information (PCI)	• T1003: Credential Dumping	4 (Like…	5 (Cata…
payment processing server	Payment information (PCI)	• T1190: Exploit Public-Facing Application	2 (Unli…	5 (Cata…
employees	Payment information (PCI) Intellectual property (IP)	• T1078: Valid Accounts	4 (Like…	4 (Major)
PCI	Payment information (PCI)	• T1555: Credentials from Password Stores	2 (Unli…	5 (Cata…
PCI software	Payment information (PCI)	• T1609: Container Administration Command	2 (Unli…	5 (Cata…
network traffic	Payment information (PCI) personally identifiable information (PII) In-game private chat system	• T1040: Network Sniffing	3 (Pos…	3 (Mod…
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig…

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...
		• TTP ID (TTP Name)	1 (Rare)	1 (Insig...

🗺️ Solution Roadmap



Solution Roadmap for Xibalba Interactive

🍯 Honey strategies

🍯 Honey strategy Solutions:

🍯 **Honey strategy Solutions:** **1**
Solution #1 Web bug on internal web server containing IP 2
STAKEHOLDERS 2
Executives 2
IT Team 2
Legal 2
GOALS 2
implement Web bug on internal server 2
Test web bug 3
Early Intrusion Detection 3
Solution #2 Honey creds in credentials server 3
STAKEHOLDERS 3
Executives 3
IT Team 3
Legal 3
GOALS 3
Implement a honey cred 3
Test honey cred alert 4
Divert and Delay Attackers 4
Solution #3 Honey token in live game chat 4
STAKEHOLDERS 4
Executives 4
IT Team 4
Legal 4
GOALS 4
Early Detection 4
Identify Compromised Accounts 5
Gather Threat Intelligence 5
Solution #4 NAME HERE 5
STAKEHOLDERS 5
Executives 5
IT Team 5
Legal 5
GOALS 5
ADD GOAL #1 NAME HERE 5
ADD GOAL #2 NAME HERE 5

ADD GOAL #3 NAME HERE....5
Solution #5 NAME HERE....5
STAKEHOLDERS....6
Executives....6
IT Team....6
Legal....6
GOALS....6
ADD GOAL #1 NAME HERE....6
ADD GOAL #2 NAME HERE....6
ADD GOAL #3 NAME HERE....6

🍯 Honeypot Solution #1		
Solution #1 Web bug on internal web server containing IP	**Difficulty:** 1 (Easy)	**Priority:** 3 (High)
Detect if a directory enumeration is performed on dev.xibalbainteractive.com (IP)		
Addresses attack vector(s):	- T1190: Exploit Public-Facing Application	
Protects key asset(s):	- Intellectual property (IP)	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
By monitoring access patterns and identifying suspicious behavior, we can proactively respond to threats, protecting our valuable intellectual property and minimizing financial risks. This provides an additional layer of security, safeguarding our competitive advantage and ensuring business continuity.	This will enable us to identify unauthorized access attempts, suspicious scanning activity, and other indicators of compromise, allowing for faster incident response and containment. This added layer of monitoring enhances our visibility into internal network activity and strengthens our overall security posture.	By logging access attempts and suspicious activity, we can gather evidence to support investigations and demonstrate due diligence in protecting our intellectual property. This proactive monitoring measure strengthens our legal position in the event of a security incident.
GOALS		
Name	**Description**	**Deadline**
implement Web bug on internal server	Implement Web bug on internal web server containing IP in one	One week

	month	
Test web bug	Test web bug is alerting properly after implementation	2 weeks
Early Intrusion Detection	By monitoring access patterns and identifying suspicious activity, the web bug can alert security teams to potential threats before they escalate.	2 weeks

🍯 Honeypot Solution #2		
Solution #2 Honey creds in credentials server	**Difficulty:** 1 (Easy)	**Priority:** 3 (High)
Detects if credentials are being viewed for PCI,PII,or IP.		
Addresses attack vector(s):	- T1555: Credentials from Password Stores, - T1609: Container Administration Command	
Protects key asset(s):	- Intellectual property (IP) - Payment information (PCI) - personally identifiable information (PII)	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
Any use of these fake credentials immediately signals a potential breach, allowing us to quickly respond and contain the incident, minimizing potential damage to our business. This proactive measure significantly enhances our security posture and protects our critical assets.	Deploying honeypot credentials on the credential server creates a valuable early detection system for unauthorized access attempts.	Implementing honeypot credentials on the credential server enables early detection and documentation of unauthorized access attempts, providing valuable evidence for potential legal proceedings.
GOALS		
Name	**Description**	**Deadline**
Implement a honey cred	Detect unauthorized access attempts to the credential server by identifying any usage of the honeypot credentials.	One week

Test honey cred alert	Regularly test the honeypot credentials to ensure they are properly configured and generating alerts when accessed.	Two weeks
Divert and Delay Attackers	By presenting attackers with fake credentials, the honeypot can slow them down and provide valuable time for security teams to take action.	Two weeks

🍯 Honeypot Solution #3		
Solution #3 Honey token in live game chat	**Difficulty:** 1 (Easy)	**Priority:** 3 (High)
Detects if in game chat is being viewed by an outside threat.		
Addresses attack vector(s):	- T1557: Adversary-in-the-Middle	
Protects key asset(s):	- In-game private chat system	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
This proactive measure protects our users' data, safeguards our intellectual property, and maintains the integrity of our gaming environment.	Any attempts to access or exfiltrate this token will trigger immediate alerts, allowing us to quickly identify and respond to security incidents. This enhances our ability to detect and contain threats, improving the overall security of our gaming environment.	Any interaction with this fake token serves as a clear indication of malicious activity, strengthening our ability to investigate breaches, assess damages, and demonstrate due diligence in protecting user data. This proactive measure supports our legal position in the event of a security incident.
GOALS		
Name	**Description**	**Deadline**
Early Detection	Detect unauthorized attempts to extract or exfiltrate data from the game chat by monitoring access to the honey token.	2 weeks

Identify Compromised Accounts	Detect compromised user accounts that are being used to access or distribute the honey token within the game chat	3 weeks
Gather Threat Intelligence	Collect information about the attacker's tactics, techniques, and procedures (TTPs) by analyzing their behavior when they interact with the honey token.	3 weeks

🍯 Honeypot Solution #4		
Solution #4 NAME HERE	**Difficulty:** 1 (Easy)	**Priority:** 1 (Low)
ADD SOLUTION SUMMARY HERE		
Addresses attack vector(s):	- LIST RELEVANT ATT&CK TTPs HERE	
Protects key asset(s):	- LIST RELEVANT KEY ASSETS HERE	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
ADD EXECUTIVE ARGUMENT HERE.	ADD IT TEAM ARGUMENT HERE.	ADD LEGAL ARGUMENT HERE.
GOALS		
Name	**Description**	**Deadline**
ADD GOAL #1 NAME HERE		
ADD GOAL #2 NAME HERE		
ADD GOAL #3 NAME HERE		

🍯 Honeypot Solution #5		
Solution #5 NAME HERE	**Difficulty:** 1 (Easy)	**Priority:** 1 (Low)
ADD SOLUTION SUMMARY HERE		

Addresses attack vector(s):	- LIST RELEVANT ATT&CK TTPs HERE	
Protects key asset(s):	- LIST RELEVANT KEY ASSETS HERE	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
ADD EXECUTIVE ARGUMENT HERE.	ADD IT TEAM ARGUMENT HERE.	ADD LEGAL ARGUMENT HERE.
GOALS		
Name	**Description**	**Deadline**
ADD GOAL #1 NAME HERE		
ADD GOAL #2 NAME HERE		
ADD GOAL #3 NAME HERE		

📊 Data sources

📊 Data Sources:

📊 **Data Sources:** **1**
Solution #1 DS0009: Process 2
STAKEHOLDERS 2
Executives 2
IT Team 2
Legal 2
GOALS 2
Push data source to SIEM 2
Maintain data source 3
Identify 100% of malicious API traffic 3
DS0015: Application Log 3
STAKEHOLDERS 3
Executives 3
IT Team 3
Legal 3
GOALS 3
Implement Application Log Content 3
Conduct audits of application logs 3
Identify 100% of malicious application traffic 3
Solution #3 DS0017: Command 4
STAKEHOLDERS 4
Executives 4
IT Team 4
Legal 4
GOALS 4
Detect Anomalous Command Execution 4
Monitor for Privilege Escalation Attempts 4
Identify Data Exfiltration Attempts 5
Solution #4 NAME HERE 5
STAKEHOLDERS 5
Executives 5
IT Team 5
Legal 5
GOALS 5
ADD GOAL #1 NAME HERE 5
ADD GOAL #2 NAME HERE 5

ADD GOAL #3 NAME HERE....5
Solution #5 NAME HERE....5
STAKEHOLDERS....5
Executives....5
IT Team....5
Legal....5
GOALS....6
ADD GOAL #1 NAME HERE....6
ADD GOAL #2 NAME HERE....6
ADD GOAL #3 NAME HERE....6

📊 Data Source Solution #1		
Solution #1 DS0009: Process	**Difficulty:** 2 (Medium)	**Priority:** 3 (High)
Monitor for API calls that may search local system sources, such as file systems or local databases, to find files of interest and sensitive data prior to Exfiltration.		
Addresses attack vector(s):	- T1555.03: Credentials from Web Browsers - T1005: Data from Local System - T1040: Network Sniffing	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
By monitoring process behavior, we can identify anomalous activity associated with compromised accounts or malware infections, preventing data breaches and minimizing business disruption. Investing in process monitoring enhances our security posture and protects our valuable assets.	This data enables us to detect malicious processes, unauthorized software installations, and potential security breaches, allowing for timely remediation. Integrating process monitoring into our security stack is crucial for maintaining a secure and reliable environment.	Monitoring process data provides valuable forensic information in the event of a security incident, aiding in investigations and demonstrating due diligence. Log activity allows us to identify the root cause of breaches, assess the extent of data compromise, and strengthen our legal defense.
GOALS		
Name	**Description**	**Deadline**
Push data source to SIEM	Leverage tools to monitor API	One month deadline

	execution behaviors at the process level.	
Maintain data source.	Ensure proper API user behavior collecting audits monthly	monthly
Identify 100% of malicious API traffic	Continuously identify all malicious traffic	Three months

📊 Data Source Solution #2		
DS0015: Application Log	**Difficulty:** 2 (Medium)	**Priority:** 3 (High)
Monitor application logs for changes to settings and other events associated with network protocols and other services commonly abused for AiTM.		
Addresses attack vector(s):	- T1557: Adversary-in-the-Middle - T1190: Exploit Public-Facing Application - T1199: Trusted Relationship	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
Our goal is to provide the best monitoring possible. Monitoring applications would not only increase security, but provide better integrity of our network as a whole.	This will reduce time and effort into finding potential threats within the network.	With the provided data source implemented it would provide documentation for legal reasons and be compliant with regulations. It will provide breach notification and provide a better picture of risk management.
GOALS		
Name	**Description**	**Deadline**
Implement Application Log Content	Deploy Application Log Content to be monitored within two months	Two months
Conduct audits of application logs	Collect audits monthly to identify all malicious traffic	monthly
Identify 100% of malicious application traffic	Identify 100% of malicious application traffic within 3 months	Three months

📊 Data Source Solution #3

Solution #3 DS0017: Command	**Difficulty:** 2 (Medium)	**Priority:** 2 (Medium)
Monitor command execution within containers to detect suspicious activity. Commands executed via Docker (docker exec) or Kubernetes (kubectl exec) should be captured along with relevant metadata.		
Addresses attack vector(s):	- T1609: Container Administration Command - T1555: Credentials from Password Stores	

STAKEHOLDERS		
Executives	**IT Team**	**Legal**
Investing in command monitoring strengthens our security posture and mitigates the risk of costly breaches.	Command data provides essential insight into user activity and system behavior, allowing us to identify anomalies and potential security threats. Analyzing command-line logs helps us detect unauthorized commands, suspicious scripts, and other indicators of compromise, enabling us to respond quickly and effectively. Integrating command monitoring into our security stack is crucial for maintaining a secure and reliable infrastructure.	Integrating command monitoring into our security stack is crucial for maintaining a secure and reliable infrastructure.

GOALS		
Name	**Description**	**Deadline**
Detect Anomalous Command Execution	Develop SIEM rules to identify unusual or suspicious commands executed by users, especially privileged users, that deviate from established baselines.	1 month
Monitor for Privilege Escalation Attempts	Implement alerts to identify commands associated with privilege escalation techniques	1 month

Identify Data Exfiltration Attempts	Create SIEM rules to detect commands associated with data exfiltration,	1 month

📊 Data Source Solution #4		
Solution #4 NAME HERE	**Difficulty:** 1 (Easy)	**Priority:** 1 (Low)
ADD SOLUTION SUMMARY HERE		
Addresses attack vector(s):	- LIST RELEVANT ATT&CK TTPs HERE	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
ADD EXECUTIVE ARGUMENT HERE.	ADD IT TEAM ARGUMENT HERE.	ADD LEGAL ARGUMENT HERE.
GOALS		
Name	**Description**	**Deadline**
ADD GOAL #1 NAME HERE		
ADD GOAL #2 NAME HERE		
ADD GOAL #3 NAME HERE		

📊 Data Source Solution #5		
Solution #5 NAME HERE	**Difficulty:** 1 (Easy)	**Priority:** 1 (Low)
ADD SOLUTION SUMMARY HERE		
Addresses attack vector(s):	- LIST RELEVANT ATT&CK TTPs HERE	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
ADD EXECUTIVE ARGUMENT HERE.	ADD IT TEAM ARGUMENT HERE.	ADD LEGAL ARGUMENT HERE.

GOALS		
Name	**Description**	**Deadline**
ADD GOAL #1 NAME HERE		
ADD GOAL #2 NAME HERE		
ADD GOAL #3 NAME HERE		

🔮 Mitigations

🔮 Preventive Mitigations:

🔮 **Preventive Mitigations:** **1**
M1015: Active Directory Configuration 2
STAKEHOLDERS 2
Executives 2
IT Team 2
Legal 2
Active Directory Configuration 2
GOALS 2
Centralized Access Control 2
Eliminate shared database credentials between development and production environments 2
Audit and Compliance 2
Security Posture 2
Solution #2 M1026: Privileged Account Management 3
STAKEHOLDERS 3
Executives 3
IT Team 3
Legal 3
GOALS 3
Implement multi-factor authentication (MFA) and IP whitelisting 3
Enforce strict separation between development and production environments 4
Harden VPN Access to Development Servers: 4
Solution #3 M1027: Password Policies 4
STAKEHOLDERS 4
Executives 4
IT Team 4
Legal 4
GOALS 5
Establish a Centralized Password Policy 5
Enforce Password Complexity Requirements 5
Require Regular Password Expiration 5

🔮 Preventive Solution #1		
M1015: Active Directory Configuration	**Difficulty:** 3 (Hard)	**Priority:** 3 (High)
Manage the access control list for "Replicating Directory Changes All" and other permissions associated with domain controller replication. Consider adding users to the "Protected Users" Active Directory security group. This can help limit the caching of users' plaintext credentials.		
Addresses attack vector(s):	- T1003: Credential Dumping, - T1078: Valid Accounts - T1649: Steal or Forge Authentication Certificates	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
This isn't just an IT security issue - it's a business survival issue. The cost of implementing proper Active Directory configuration is minimal compared to the potential losses from a major security incident.	Instead of having scattered user accounts across different systems, Active Directory will create a single, centralized place to manage all user identities and permissions. Making it easier to manage.	Active Directory Configuration provides the legal team with centralized audit trails and access controls that are essential for regulatory compliance and incident response.
GOALS		
Name	**Description**	**Deadline**
Centralized Access Control	Eliminate shared database credentials between development and production environments	2 months
Audit and Compliance	Generate comprehensive audit trails for all user access across systems	6 months
Security Posture	Implement role-based access control (RBAC) to limit privilege escalation	3 months

🔮 Preventive Solution #2

Solution #2 M1026: Privileged Account Management	**Difficulty:** 2 (Medium)	**Priority:** 3 (High)

Privileged Account Management focuses on implementing policies, controls, and tools to securely manage privileged accounts (e.g., SYSTEM, root, or administrative accounts). This includes restricting access, limiting the scope of permissions, monitoring privileged account usage, and ensuring accountability through logging and auditing.

Addresses attack vector(s):	- T1003: Credential Dumping, - T1190: Exploit Public-Facing Application, - T1505: Server Software Component, - T1078: Valid Accounts, - T1609: Container Administration Command, - T1555: Credentials from Password Stores

STAKEHOLDERS

Executives	**IT Team**	**Legal**
Compromised privileged accounts pose a significant financial risk, potentially leading to millions in losses from regulatory fines, data breach lawsuits, and intellectual property theft. Without robust privileged account management, Xibalba Interactive risks losing its competitive edge and damaging its reputation, ultimately impacting revenue. Investing in privileged account management is crucial to safeguarding our valuable assets and ensuring business continuity.	This mitigation is critical to securing our infrastructure and preventing unauthorized access to sensitive systems and data. Implementing robust controls, such as multi-factor authentication and just-in-time access, will significantly reduce the attack surface and minimize the risk of privilege escalation. Prioritizing privileged account security is essential for maintaining the integrity and confidentiality of our environment and adhering to compliance requirements.	This is essential to mitigate legal and regulatory risks associated with data breaches and non-compliance. Failure to adequately manage privileged accounts can result in significant fines, lawsuits, and reputational damage, particularly concerning PCI-DSS and data protection regulations. Strengthening privileged account controls demonstrates due diligence and reduces potential liability in the event of a security incident.

GOALS

Name	**Description**	**Deadline**
Implement multi-factor authentication (MFA) and IP whitelisting	Implement all administrative interfaces, especially those accessible over the internet.	One month

Enforce strict separation between development and production environments	By using separate credentials, prevent vulnerabilities in the development environment from impacting the production environment	One month
Harden VPN Access to Development Servers:	Reduce the risk of unauthorized access to the development environment.	One month

🔮 Preventive Solution #3		
Solution #3 M1027: Password Policies	**Difficulty:** 1 (Easy)	**Priority:** 3 (High)
Organizations may consider weighing the risk of storing credentials in web browsers. If web browser credential disclosure is a significant concern, technical controls, policy, and user training may be used to prevent storage of credentials		
Addresses attack vector(s):	- T1555.03: Credentials from Web Browsers - T1003: Credential Dumping - T1078: Valid Accounts - T1555: Credentials from Password Stores	
STAKEHOLDERS		
Executives	**IT Team**	**Legal**
Strong passwords protect valuable assets like game code and user data, minimizing financial and legal exposure. M1027 reduces the likelihood of unauthorized access, safeguarding the company's competitive advantage and ensuring business continuity.	Password Policies are crucial for maintaining a secure IT environment and preventing unauthorized access to systems and data. Enforcing strong password requirements, regular password changes, and multi-factor authentication enhances our overall security posture. Implementing these policies reduces the risk of credential compromise and protects against potential attacks.	Robust password policies are vital for complying with data protection regulations and minimizing legal liability. Weak passwords increase the risk of data breaches, potentially leading to lawsuits, fines, and reputational harm. Implementing and enforcing strong password policies demonstrates due diligence and strengthens our defense against legal claims.

GOALS		
Name	**Description**	**Deadline**
Establish a Centralized Password Policy	Create a comprehensive, documented password policy that covers all systems and applications.	1 month
Enforce Password Complexity Requirements	Mandate the use of strong passwords with minimum length, character diversity	1 month
Require Regular Password Expiration	Enforce periodic password changes	Every 90 days